

Security Incident Report

Cloudora Security Operations | Incident Report **CLD-IR-0002**

Report ID	CLD-IR-0002
Related Ticket	CLD-0002 - Targeted Credential Phishing Impersonating Cloudora HR (Payroll Theme)
Report Title	Targeted Payroll Credential Phishing Campaign and Account Compromise Investigation
Analyst	SOC Lead Analyst, Cloudora Security Operations Engagement
Date of Report (UTC)	2026-08-25
Incident Severity	P1 - CRITICAL (Active Cloud Directory Compromise, Live Credential Theft, Unauthorized Cloud Access)
Status	Contained & Eradicated (Post-Incident Verification & Monitoring Ongoing)
Classification	CONFIDENTIAL - Internal & Client Distribution Only

1. Executive Summary

On 25 August 2026, an external threat actor launched a coordinated, payroll-themed credential phishing campaign targeting 40 employees at Cloudora. The adversary distributed two operational variants: one forging Cloudora’s legitimate internal domain (`payroll@cloudora.io`) which failed all transport authentication checks, and a secondary variant from a deceptive lookalike domain (`cloudora-hr-portal.example`) configured with valid cryptographic authentication. Telemetry confirmed that six employees clicked the malicious hyperlinks, and two individuals submitted their corporate credentials into the harvesting portal.

Within hours of credential submission, the attacker successfully authenticated to both compromised accounts from a hosted endpoint located in Amsterdam, accessing cloud email and document repositories. Following an initial report by an observant employee, the Security Operations Center (SOC) initiated rapid containment: terminating all active session tokens, forcing enterprise password resets, enforcing multi-factor authentication, blacklisting all adversarial network infrastructure and domains, and executing a zero-hour mailbox purge across the organization. Forensics confirmed that the attacker did not execute unauthorized financial modifications or establish persistence. Precautionary credential rotations and awareness notifications have been initiated for all impacted and near-miss recipients.

2. Incident Timeline

All timestamps are recorded in **Coordinated Universal Time (UTC)**.
Telemetry Sources: Exchange Online Message Trace (`CloudoraMsgTrace_CL`), Microsoft Entra ID Sign-In Logs (`CloudoraSignIn_CL`), and Raw RFC 822 Email Submissions (`.eml`).

Time (UTC)	Source	Event Classification	Operational Description & Supporting Evidence
06:58:00	CloudoraMsgTrace_CL	Legitimate Marketing Traffic	Corporate newsletter (<i>Cloudora Monthly</i>) delivered via Mailchimp (<code>news@cloudora.io</code>). Later reported by an employee and formally cleared as a false positive.
08:04–08:20	CloudoraMsgTrace_CL	Adversary Ingress (Wave 1)	Variant A dispatched from <code>198.18.44.10</code> spoofing <code>payroll@cloudora.io</code> . Exchange Online Protection (EOP) quarantined 4 copies; 16 reached target user inboxes.
08:35–08:50	CloudoraMsgTrace_CL	Adversary Ingress (Wave 2)	Variant A Wave 2 dispatched from <code>198.18.44.23</code> ; Variant B dispatched from <code>198.18.51.7</code> utilizing lookalike domain <code>cloudora-hr-portal.example</code> (passing authentication).

Time (UTC)	Source	Event Classification	Operational Description & Supporting Evidence
08:39:03	CloudoraMsgTrace_CL	Phishing Interaction	seth.lane navigates to Variant A harvesting URL; session terminated prior to form submission (CredentialsSubmitted = No).
08:47:12	CloudoraMsgTrace_CL	Credential Theft (Victim 1)	freya.lynn opens Variant A URL and submits corporate credentials (CredentialsSubmitted = Yes).
09:05:44	CloudoraMsgTrace_CL	Credential Theft (Victim 2)	ryan.boyd opens Variant B URL and submits corporate credentials (CredentialsSubmitted = Yes).
09:11:00	SecOps Ticketing	Incident Inception	james.holt forwards suspicious payroll email to the SOC; Ticket CLD-0002 created; forensic triage initiated.
09:58:00	CloudoraMsgTrace_CL	Phishing Interaction	hugo.marsh accesses phishing hyperlink; no credentials entered (CredentialsSubmitted = No).
10:12:00	CloudoraMsgTrace_CL	Phishing Interaction	chloe.price accesses phishing hyperlink; no credentials entered (CredentialsSubmitted = No).
10:34:20	CloudoraSignIn_CL	Unauthorized Sign-In (Victim 1)	Attacker signs into freya.lynn@cloudora.io from Amsterdam IP 198.18.7.200 via Chrome on Windows 11 (MITRE ATT&CK T1078.004). Impossible travel vs Manchester morning activity.
10:36–10:41	CloudoraSignIn_CL	Unauthorized Resource Access	Attacker accesses Outlook Web App (10:36 UTC) and SharePoint Online (10:41 UTC) under freya.lynn identity.
11:47:00	CloudoraMsgTrace_CL	Phishing Interaction	dina.said accesses phishing hyperlink; no credentials entered (CredentialsSubmitted = No).
13:22:05	CloudoraSignIn_CL	Unauthorized Sign-In (Victim 2)	Attacker signs into ryan.boyd@cloudora.io from Amsterdam IP 198.18.7.200 via Chrome on Windows 11 using harvested credentials.
13:25:33	CloudoraSignIn_CL	Unauthorized Resource Access	Attacker accesses Outlook Web App under ryan.boyd identity.
14:00:00	SOC Active Response	Containment & Remediation	SOC executes session revocation, directory password resets, edge IP/domain blacklisting, and tenant-wide zero-hour mailbox purge.

3. Investigation Findings

Finding 1 — Coordinated Impersonation Campaign Dispatched to Enterprise Mailboxes

A targeted phishing campaign delivered 40 malicious messages to Cloudora staff themed around urgent payroll verification ("Payroll update: action required before 5pm" and "Action required: confirm your August payroll details"). Telemetry confirmed that 36 mailboxes received the messages directly into their primary inbox, while 4 messages were intercepted and quarantined by Exchange Online Protection (EOP).

Evidence: CloudoraMsgTrace_CL delivery logs and raw email artifacts.

Finding 2 — Asymmetric Transport Authentication and Lookalike Infrastructure

The threat actor deployed two distinct delivery tactics:

- Variant A (Direct Spoofing):** Forged the internal sender header payroll@cloudora.io via relays 198.18.44.10 and 198.18.44.23. This triggered explicit transport authentication failures (compauth=fail reason=001, spf=fail, dkim=fail, dmarc=fail).
- Variant B (Lookalike Domain):** Originated from 198.18.51.7 using registered lookalike domain cloudora-hr-portal.example. This variant passed SPF, DKIM, and DMARC checks because the attacker controlled DNS records for the lookalike entity.

Significance: Passing cryptographic validation validates domain alignment, not operational legitimacy. Both variants routed users to malicious credential harvesting endpoints.

Finding 3 — Credential Harvest and Cloud Account Compromise

Two employees, `freya.lynn@cloudora.io` (08:47:12 UTC) and `ryan.boyd@cloudora.io` (09:05:44 UTC), entered enterprise credentials on the adversary's landing pages (`CredentialsSubmitted = Yes`). The threat actor subsequently utilized these credentials to execute unauthorized interactive cloud sign-ins from an Amsterdam host (`198.18.7.200`) at 10:34:20 UTC and 13:22:05 UTC respectively. The adversary accessed Outlook Web App and SharePoint Online repositories.

Significance: Demonstrates valid cloud account exploitation (MITRE ATT&CK T1078.004) following spearphishing credential harvesting.

Finding 4 — User Link Interaction Without Credential Exposure

Four employees (`seth.lane` , `chloe.price` , `hugo.marsh` , and `dina.said`) clicked the phishing URL but disconnected without entering or submitting authentication credentials (`CredentialsSubmitted = No`). Forensic review of Entra ID sign-in telemetry for all four accounts revealed zero unauthorized access attempts or impossible-travel anomalies.

Significance: These accounts remain secure but are categorized at elevated risk, warranting precautionary password rotations.

Finding 5 — Targeted Enterprise Scope Breakdown

Of the 40 targeted recipients: **2 accounts** were compromised via credential submission and subsequent login; **4 accounts** clicked the hyperlink without submitting credentials; **30 accounts** received the phishing email in their inbox but did not interact with the link (forming the near-miss awareness cohort); and **4 accounts** had all delivered copies quarantined by perimeter EOP controls.

Finding 6 — Legitimate Marketing Communication Cleared (False Positive)

An employee forwarded an internal marketing email ("Cloudora Monthly") distributed via Mailchimp (`news@cloudora.io`) suspecting it was related to the payroll attack. Header analysis confirmed valid DKIM signatures aligned to `cloudora.io` and `mcsv.net` , passing SPF and DMARC policies (`action=none`), and strictly authentic destination URLs.

Significance: Validated as legitimate marketing correspondence; formally cleared from incident scope to eliminate investigative ambiguity.

4. Indicators of Compromise (IOCs)

All network indicators and URLs have been defanged to prevent accidental execution.

Type	Indicator Value	Analytical Context & Attribution
Domain	<code>cloudora-hr-portal[.]example</code>	Malicious typosquatted domain used for credential harvesting and lookalike mail relay
Hostname	<code>login.cloudora-hr-portal[.]example</code>	Harvesting landing host for Variant B campaigns
Hostname	<code>mail.cloudora-hr-portal[.]example</code>	Mail exchange hostname referenced in inbound relay hops
URL	<code>hxtps://cloudora-hr-portal[.]example/payroll/login</code>	Variant A credential harvesting link
URL	<code>hxtps://login.cloudora-hr-portal[.]example/verify</code>	Variant B credential harvesting link
IPv4	<code>198.18.44.10</code>	Variant A (Wave 1) outbound relay & synthetic host
IPv4	<code>198.18.44.23</code>	Variant A (Wave 2) outbound relay (same <code>/24</code> subnet)
IPv4	<code>198.18.51.7</code>	Variant B outbound mail relay
IPv4	<code>198.18.7.200</code>	Adversary cloud authentication ingress IP (Amsterdam, NL)
Sender Address	<code>payroll@cloudora.io</code>	Spoofed internal sender address (Variant A)
Sender Address	<code>payroll@cloudora-hr-portal.example</code>	Deceptive lookalike sender address (Variant B)
Reply-To	<code>hr-support@cloudora-hr-portal.example</code>	Adversary-controlled extraction inbox (Variant A)
Subject	<code>Payroll update: action required before 5pm</code>	Phishing lure subject line (Variant A)
Subject	<code>Action required: confirm your August payroll details</code>	Phishing lure subject line (Variant B)

5. MITRE ATT&CK Matrix Mapping

Tactical Objective	Technique ID	Technique Designation	Log Evidence & Incident Context
Initial Access	T1566.002	Phishing: Spearphishing Link	Distribution of tailored payroll lures containing hyperlinks to external credential harvesters (Findings 1 & 2).
Credential Access	T1598.003	Phishing for Information: Spearphishing Link	Deployment of deceptive web forms mimicking enterprise HR portals to capture user credentials (Finding 3).
Initial Access / Persistence	T1078.004	Valid Accounts: Cloud Accounts	Unauthorized Entra ID authentication and cloud resource access (Outlook Web, SharePoint) using stolen employee credentials (Finding 3).
Resource Development	T1583.001	Acquire Infrastructure: Domains	Pre-operational registration of lookalike domain <code>cloudora-hr-portal.example</code> with configured DNS/SPF/DKIM records.

6. Environmental Scope

Total Targets (40 Accounts) Confirmed Compromised (2 Accounts) freya.lynn@cloudora.io (Clicked, Submitted Credentials, Attacker Login at 10:34 UTC) ryan.boyd@cloudora.io (Clicked, Submitted Credentials, Attacker Login at 13:22 UTC) Elevated Risk / Clickers (4 Accounts) seth.lane, chloe.price, hugo.marsh, dina.said (Clicked link, No credentials submitted, No anomalous sign-ins) Targeted / Delivered Non-Clickers (30 Accounts) 30 users received email in inbox without interacting (Near-miss awareness group) Perimeter Defended / Quarantined (4 Accounts) emma.hayes, maya.chen, nina.cole, ruth.dean (All copies quarantined by EOP) Cleared False Positives (1 Item) "Cloudora Monthly" Newsletter via Mailchimp (news@cloudora.io - Verified DKIM/DMARC)

7. Containment, Eradication & Remediation Actions

The SOC executed remediation in strict procedural sequence to prevent concurrent attacker persistence during account recovery.

Execution Order	Operational Action	Target Entity / Scope	Strategic Justification & Verification
01	Revocation of Active Sessions & Tokens	freya.lynn ryan.boyd	Terminates attacker persistence immediately. Resetting credentials without token revocation leaves active browser and OAuth refresh tokens valid.
02	Directory Credential Reset	freya.lynn ryan.boyd	Invalidates compromised passwords in Microsoft Entra ID once active adversary sessions have been killed.
03	MFA Re-Registration & Enforcement	freya.lynn ryan.boyd	Forces re-enrollment of strong multi-factor authentication, ensuring stolen passwords cannot be replayed.

Execution Order	Operational Action	Target Entity / Scope	Strategic Justification & Verification
04	Edge & Proxy Infrastructure Blacklisting	198.18.44.10 , .23 198.18.51.7 , 198.18.7.200 *.cloudora-hr-portal.example	Blocks inbound/outbound communication across mail gateways, firewalls, and web proxies for all known attacker infrastructure.
05	Zero-Hour Mail Store Purge (ZAP)	Enterprise Mailbox Fleet	Soft-deletes all delivered copies of the phishing emails across all 36 delivered recipient mailboxes.
06	Forensic Verification & Post-Check	Sign-In & Message Logs	Re-ran sign-in queries for 198.18.7.200 and victim UPNs; confirmed zero adversary activity post-14:00 UTC.

8. Strategic Recommendations

Tactical Wins (Immediate Execution)

- **Precautionary Resets for Link Clickers:** Enforce password rotations and provide 1-on-1 check-ins for the four users who visited the phishing landing page (seth.lane , chloe.price , hugo.marsh , dina.said).
- **Targeted Near-Miss Awareness:** Dispatch a clear, non-punitive internal communication to the 30 employees who received the phishing email, reinforcing reporting protocols.
- **Elevate DMARC Policy to Enforcement (p=reject):** Upgrade cloudora.io DMARC configuration from monitoring (p=none / p=quarantine) to p=reject , ensuring spoofed messages (Variant A) are rejected outright across all global mail servers.
- **Deploy KQL Click-to-Login Analytic Rule:** Implement the continuous correlation rule linking external phishing URL clicks with subsequent foreign/anomalous sign-ins within a 4-hour window.

Strategic Safeguards (Long-Term Resilience)

- **Tenant-Wide Phishing-Resistant MFA:** Transition all Cloudora identities to FIDO2 hardware security keys or Microsoft Authenticator number-matching policies, mitigating adversary-in-the-middle (AiTM) and credential replay attacks.
- **Mail Gateway Inbound Lookalike Inspection:** Configure custom mail transport rules to flag or quarantine incoming messages from newly registered domains (<30 days old) containing brand keywords (cloudora , payroll , hr-portal).
- **Automated Incident Response Playbooks:** Implement automated SOAR playbooks in Microsoft Sentinel to revoke user tokens and trigger mailbox ZAP automatically upon high-confidence phishing triage.

9. Lessons Learned

- **User Reporting Velocity is Crucial:** The incident was detected and triaged because an observant employee (james.holt) reported the email within an hour. Maintaining accessible, positive reporting workflows directly shortens time-to-containment.
- **Always Pivot Beyond the First Reported Victim:** Limiting forensic investigation to the initially reported ticket would have missed ryan.boyd 's compromised session. Pivoting on the adversary's sign-in IP (198.18.7.200) was decisive in identifying the full incident scope.
- **Authentication Passes Do Not Equal Benign Traffic:** Variant B demonstrated that adversaries can register lookalike domains and pass SPF/DKIM/DMARC checks cleanly. SOC analysts must verify **which domain** passed authentication, rather than relying solely on pass/fail indicators.
- **Automated Detection Closes the Response Gap:** The delay between credential entry and unauthorized sign-in (1 to 4 hours) presents an optimal detection window. Deploying automated cross-telemetry correlation rules eliminates reliance on manual end-user reporting.

End of Incident Report CLD-IR-0002. Prepared for Cloudora Security Operations.